SIZMA TESTİ RAPORU

Rapor Tarihi	09/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Horizontal privilege escalation

Bu raporda, PortSwigger Web Security Academy'de yer alan yatay yetki yükseltmeleri ile ilgili beş farklı durum ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın yetki kontrollerinde (access control) ciddi eksiklikler tespit edilmiş ve normal/yetkisiz bir kullanıcının yönetici (admin) ayrıcalıklarına veya yetkisiz diğer kullanıcılara yetkisi olmadığı halde erişebildiği gösterilmiştir. Zafiyetin beş farklı biçimde ortaya çıktığı gözlenmiştir.

Yetkisiz yönetici erişimi ve yetkisiz diğer kullanıcı verilerine erişin sistem bütünlüğünün tümüyle tehlikeye girmesine yol açabileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1 & 2 & 3: User ID controlled by request parameter

Hedef uygulamada yapılan testler sonucunda yetkisi olmayan kullanıcının hedef kullanıcı id'sine yetkisiz şekilde erişip bu id'yi değiştirerek (durum 1-3) veya hedef kullanıcı id'sine uygulama içindeki başka özellikler sayesinde erişim sağlayabildiği (durum 2) tespit edilerek test edilmesi istenen kullanıcın api key, email değiştirme gibi işlemlerin yapılabileceği PoC adımlarıyla kanıtlanmıştır.

Durum 4: User ID controlled by request parameter with password disclosure

İlk 3 duruma ek yetkisiz kullanıcının ilgili istekte yer alan metodu yetkili kullanıcı id'si ile değiştirdiğinde yetkili hesabına erişebildiği, bu sayede de yetkili seviyesinde işlemler, kullanıcıları silme gibi, yapabildiği PoC adımlarıyla kanıtlanmıştır.

Durum 5: Insecure direct object references

Yapılan testler sonucunda hedef uygulamada yer alan canlı sohbet özelliği üzerinde yetkisiz kullanıcın çeşitli işlemler yaparak başka kullanıcıların sohbet geçmişine erişebildiği PoC adımlarıyla kanıtlanmıştır.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.2
CVSS v3.1 Vektörü	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N
CWE	CWE-639: Authorization Bypass Through User-Controlled Key

5. Etki

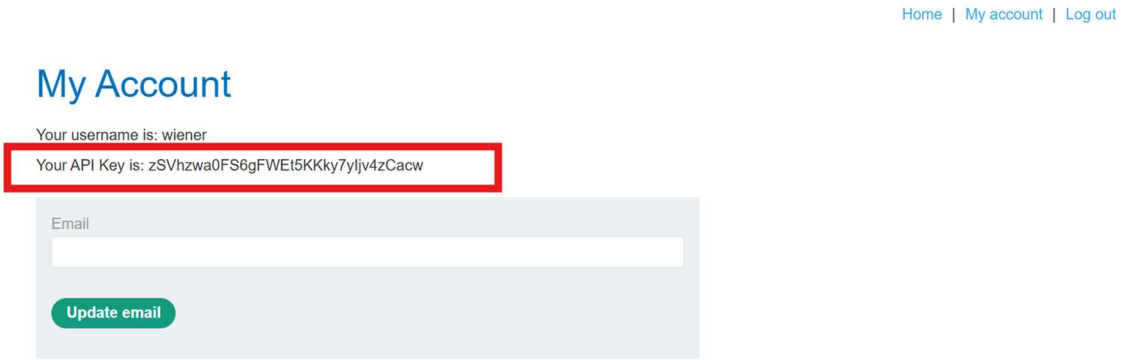
Yapılan testler sonucunda oluşan zafiyetler sayesinde yetkisiz kullanıcının yetkili bir işleve sahip olmamasına rağmen başka kullanıcılar üzerinde o kullanıcı ile ilgili api key elde etme, mail değiştirme gibi işlemleri yapabildiği doğrudan gözlemlenmiştir. Ayrıca yetkisiz kullanıcı ile yetkili kullanıcı bilgilerine de erişilebilmekte olup bu erişim ile birlikte sistemdeki diğer kullanıcıları silme gibi işlemlerin de doğrudan yapılabildiği gözlemlenmiştir.

Bu zafiyet olası olarak yetkisiz ve yetkili diğer kullanıcılara erişebilme, kullanıcılar adına işlem yapabilme, var olan kullanıcıları silebilme gibi sorunlara da yol açabilme tehlikesi taşımaktadır.

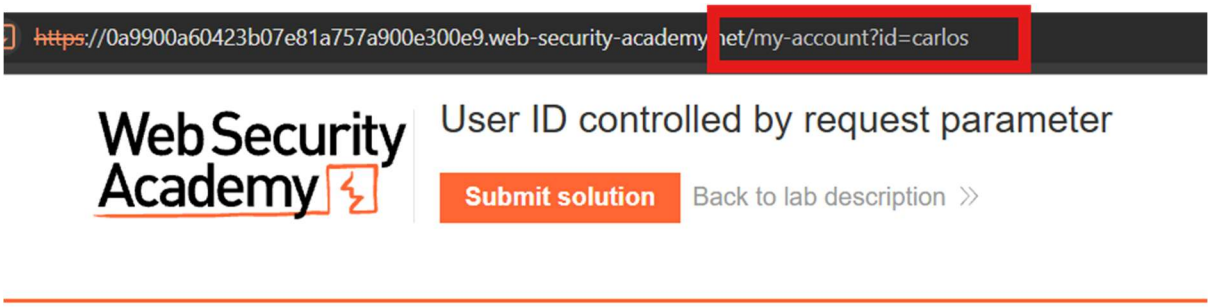
6. Proof Of Concept

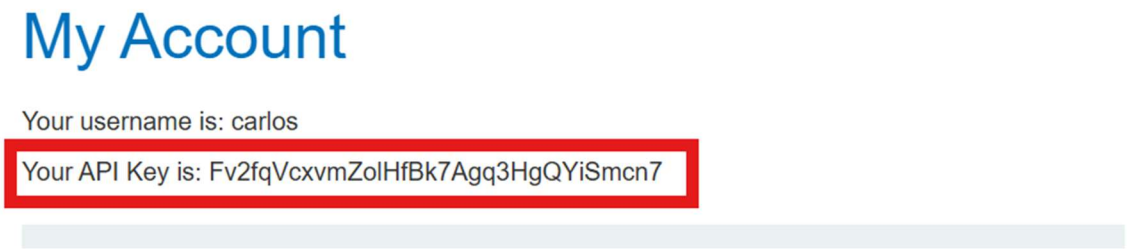
Durum 1: User ID controlled by request parameter

Verilen kimlik bilgileriyle hedef siteye giriş yapıldığında hesap sayfasında api key alanı ve mail güncelleme alanı görülmektedir. Test için istenen carlos kullanıcısının api keyini elde etmek için carlos hesabının hesap kısmına erişilmesi gerekteği görülmektedir.



Test için url kısmında yer alan /my-account?id=wiener yönlendirmesinde wiener yerine carlos yazıldığında doğrudan carlos sayfasına erişilebildiği gözlemlenmiştir. Böylelikle burada yer alan api keye de erişim sağlanabilmektedir.



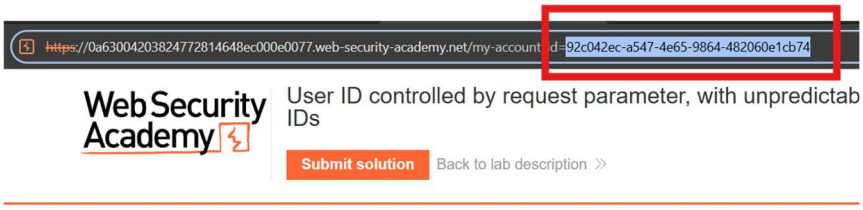


Bu sayede carlos kullanıcısının api keyi başarıyla elde edilebilmektedir.

Durum 2: User ID controlled by request parameter, with unpredictable user IDs

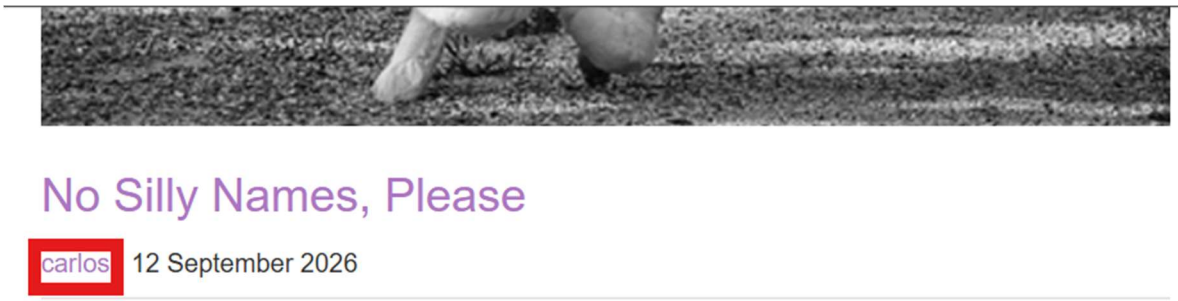
Verilen kimlik bilgileriyle hedef siteye giriş yapıldığında hesap sayfasında api key alanı ve mail güncelleme alanı görülmektedir. Test için istenen carlos kullanıcısının api keyini elde etmek için carlos hesabının hesap kısmına erişilmesi gerekteği görülmektedir.

Tet için url kısmına bakıldığında tahmin edilmesi zor, karmaşık bir id kullanıldığı görülmektedir.





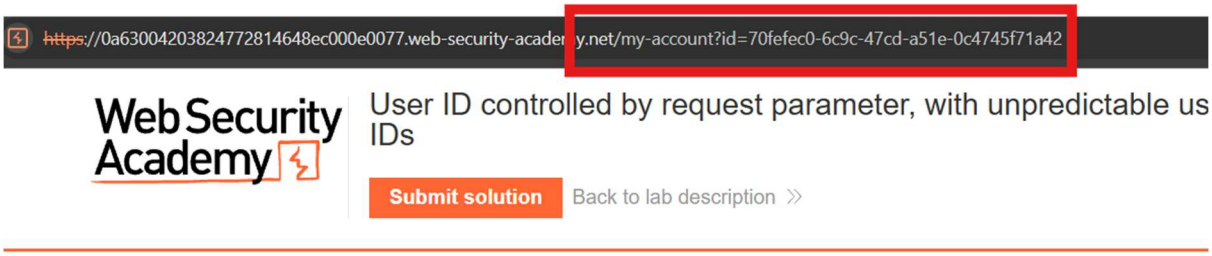
İlgili sitede yer alan blog gönderileri incelendiğinde carlos kullancısına ait bir blog yazısı ile karşılaşılmakta olup buradaki url dikkat çekicidir:

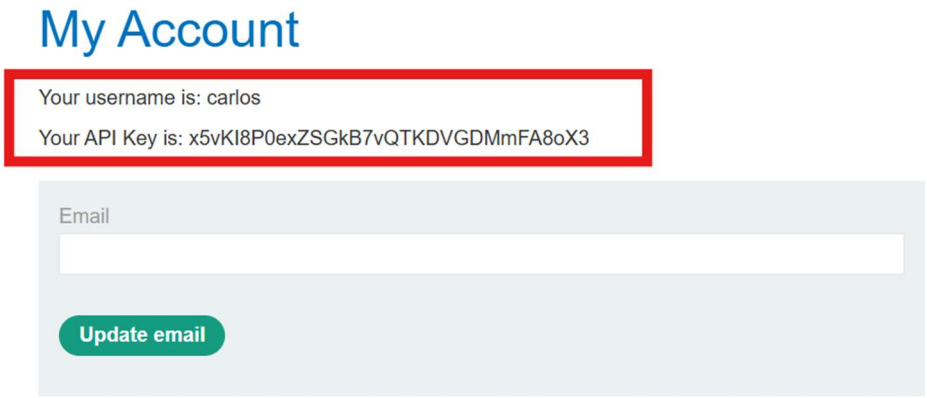


Şekil 1: carlos kullanıcısının blog gönderisi



İlgili blog gönderisinin url'i incelendiğinde doğrudan userId alanına erişilebildiği gözlemlenmiştir. Burada yer alan değer alınıp kullanıcı hesap sayfasındda yerine konulduğunda hedef kullanıcının sayfasına erişilip api keyinin alınabildiği kanıtlanmıştır.

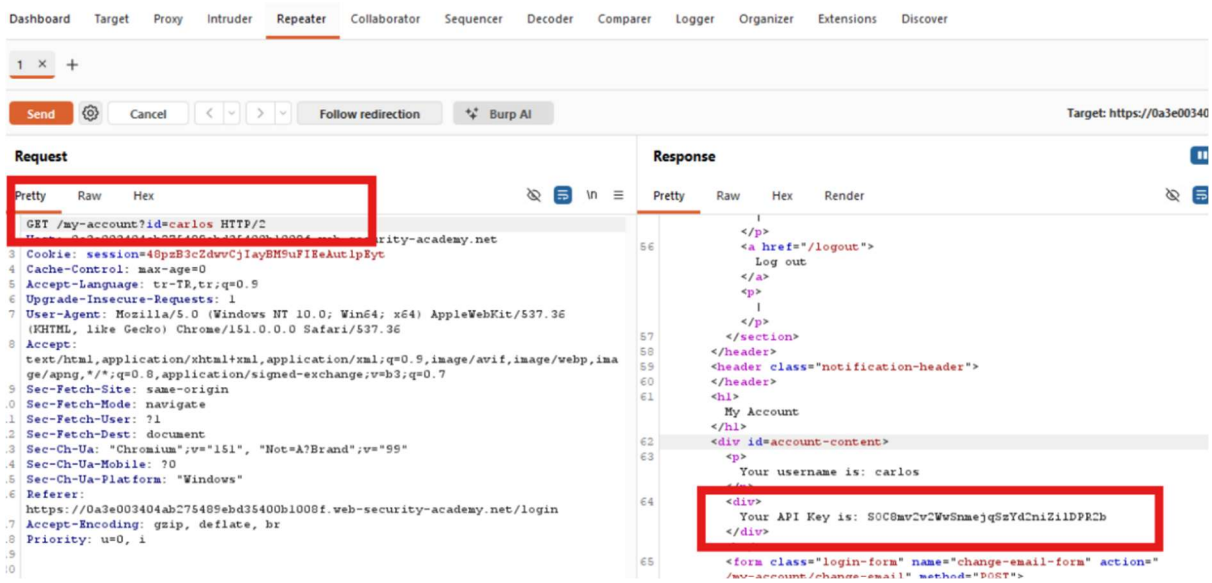




Durum 3: User ID controlled by request parameter with data leakage in redirect

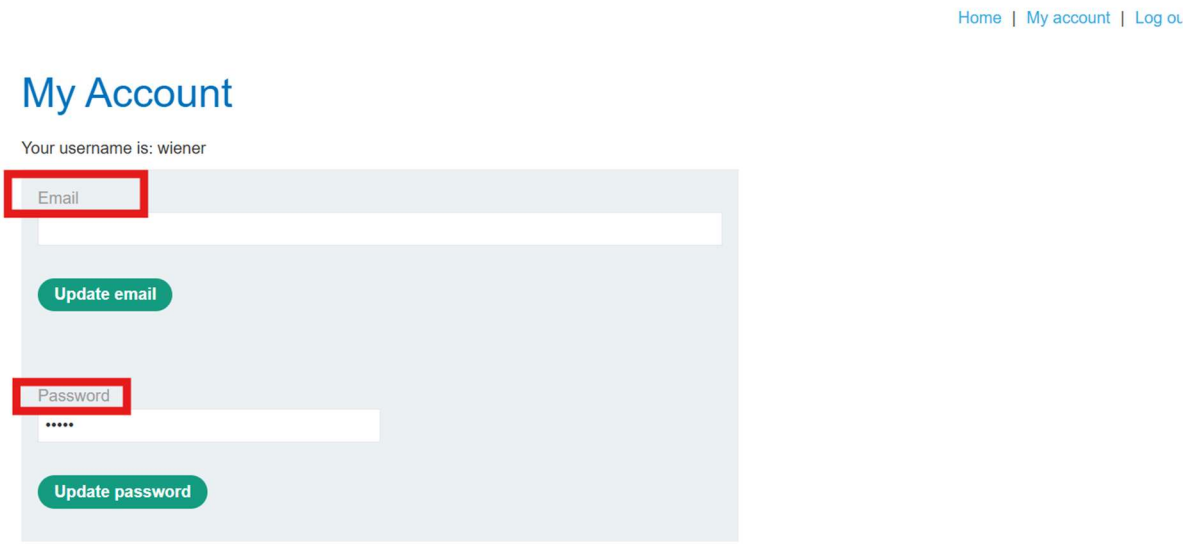
Tıpkı ilk iki durumda olduğu gibi verilen kimlik bilgileriyle hedef siteye giriş yapıldığında hesap sayfasında api key alanı ve mail güncelleme alanı görülmektedir. Test için istenen carlos kullanıcısının api keyini elde etmek için carlos hesabının hesap kısmına erişilmesi gerekteği görülmektedir.

Hesap görüntüleme isteği Burp Repeater'a gönderilip burada yer alan id test edilmesi istenen carlos kullanıcısı olarak değiştirildiğinde yanıt kısmında api key'e erişilebildği kanıtlanmıştır.



Durum 4: User ID controlled by request parameter with password disclosure

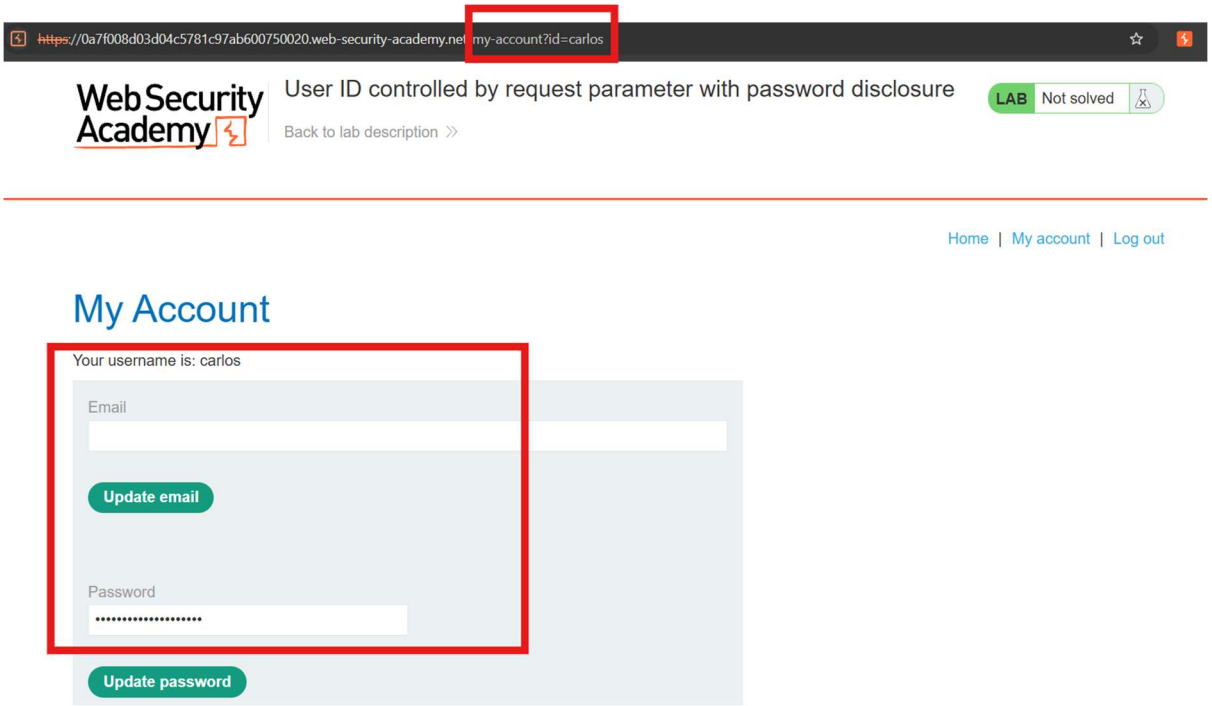
Verilen kimlik bilgileri ile hesaba giriş yapıldığında mail güncelleme ve şifre güncelleme alanları görülmektedir.



Burp Repeater'da ilgili istek incelendiğinde, metodda yer alan id alanının değiştirilerek farklı kullanıcıların bilgilerine erişilebildiği görülmektedir.

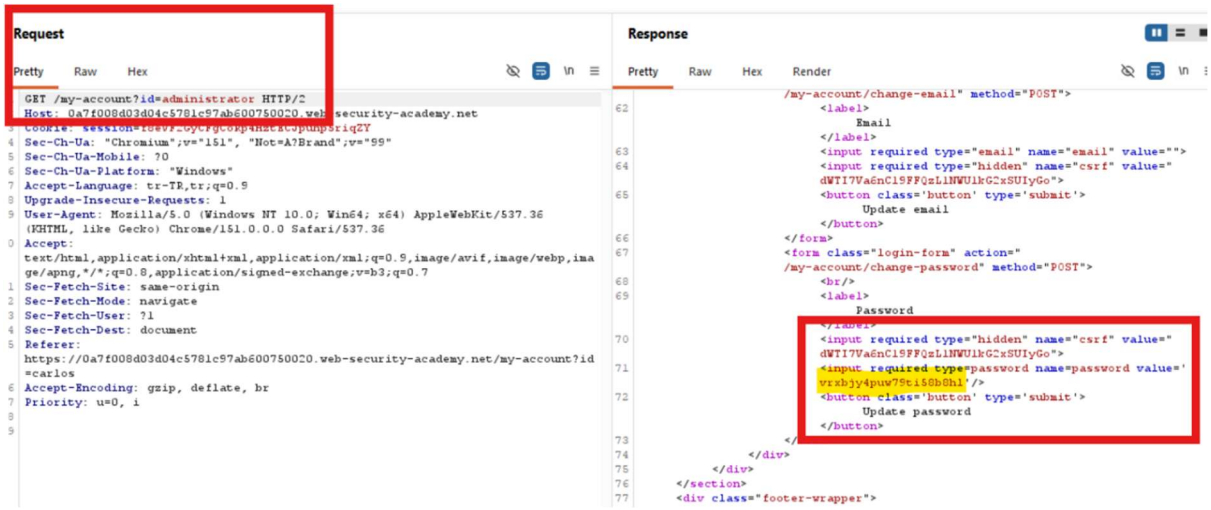
Bulgu 1: Yatay erişim ile yetkisiz kullanıcı ile diğer kullanıcı üzerinde işlem yapabilme

Test için sistemde var olduğu bilinen carlos kullanıcısına bu şekilde erişilip bu kullanıcının mail ve şifresinin değiştirilebildiği kanıtlanmıştır.



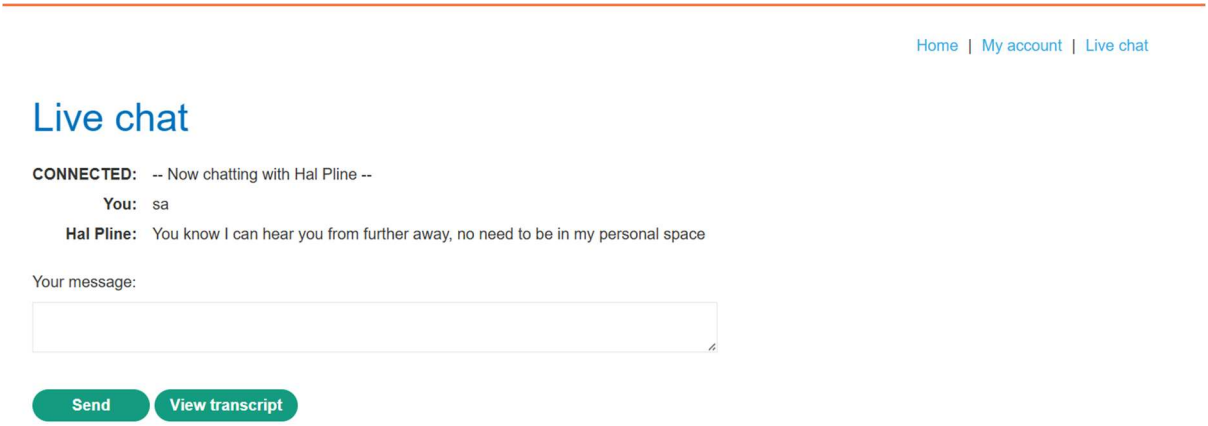
Bulgu 2: Yetkisiz kullanıcı ile yetkili kullanıcı hesabına erişebilme ve işlem yapabilme

Bulgu 1'de olduğu gibi yetkili kullanıcı olduğu bilinen administrator kullanıcısına da metoddaki id değiştirilerek ulaşılabilmekte olup böylelikle admin hesabı hakkında bilgilere erişilebilmektedir. Bu sayede sistemde var olan diğer kullanıcılar silinebilmektedir.

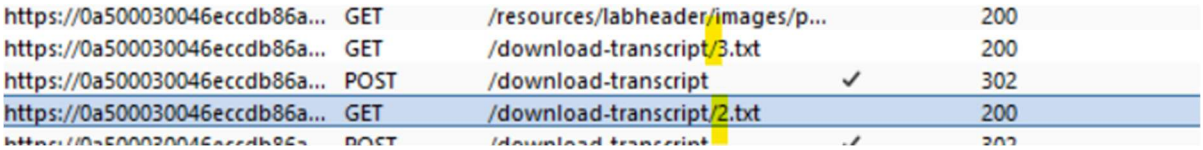


Durum 5: Insecure direct object references

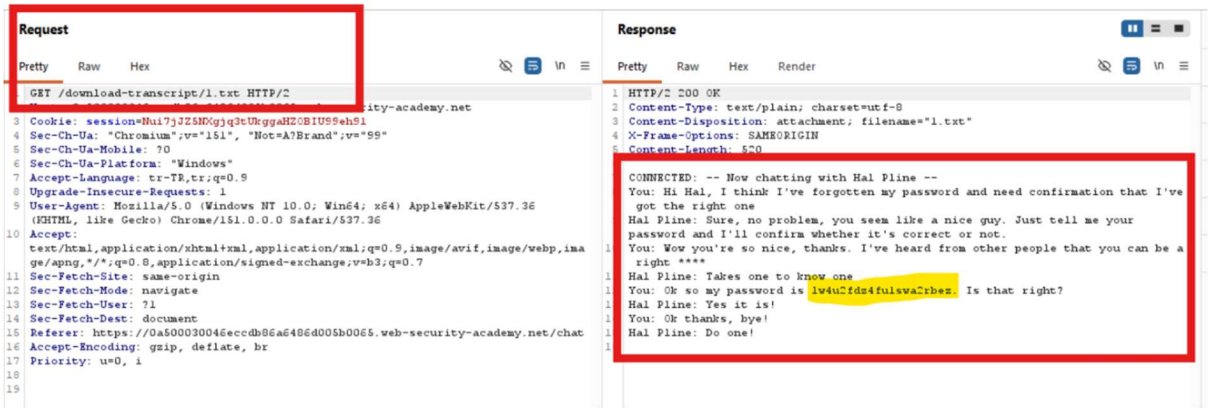
Verilen kimlik bilgileri ile hedef uygulamaya giriş yapıldığında canlı sohbet özelliği ile karşılaşılmaktadır.



Bu özellik kullanılıp "view transcript" özelliği kullanılarak sohbet geçmişinin indirilebildiği gözlemlenmekle beraber bu işlemlerin Burp Suite üzerinde incelenebildiği tespit edilmiştir.



İlgili istek Burp Repeater'a aktarılıp burada yer alan id değeri değiştirildiğinde başka bir kullanıcı olan carlos'un sohbet geçmişine erişilebildiği gözlemlenmiştir. Bu sohbet geçmişi incelendiğinde carlos'un şifresinin yer aldığı bir konuşma ile karşılaşılmaktadır. Bu sayede şifre ele geçirilebilmektedir.



7. Çözüm Önerisi

Sunucu tarafında yetki doğrulaması yapılmalıdır. Bir kaynağa (hesap sayfası, API anahtarı, döküm dosyası vb.) erişimde, istenen kaynağın isteği yapan oturum sahibine ait olup olmadığı her istekte sunucu tarafında doğrulanmalıdır. Kullanıcının kimliği, istekteki bir parametreden (id, userId vb.) değil, doğrudan oturumdan alınmalıdır.

Tahmin edilemez tanımlayıcılar tek başına yeterli savunma sayılmamalıdır. Karmaşık/rastgele ID'ler (GUID) kullanmak bir güvenlik önlemi değildir. Nitekim bu tür ID'ler uygulamanın başka noktalarında (ör. blog gönderileri) sızabilmektedir.

Hassas veriler yanıtlarda gereksiz yere döndürülmemelidir. API anahtarı, parola gibi hassas bilgiler istemciye gönderilen yanıtlarda (sayfa kaynağı, yönlendirme gövdesi, JSON yanıtı) yer almamalı; özellikle parola alanları hiçbir koşulda istemciye açık metin olarak iletilmemelidir.

Doğrudan dosya/kaynak referansları korunmalıdır. Kullanıcıya özel dosyalar (sohbet dökümleri vb.) tahmin edilebilir, sıralı adlarla (1.txt, 2.txt) ve statik URL'lerle sunulmamalı; bu dosyalara erişimde de kullanıcının o kaynağa yetkili olup olmadığı denetlenmelidir.

8. Sonuç

Yapılan testler sonucunda, hedef uygulamanın yetki kontrollerinin beş farklı biçimde atlatılabildiği ve yetkisiz bir kullanıcının yetkisi olmadığı halde diğer yetkili veya yetkisiz kullanıcıların api keyini elde etme, mail adresini değiştirme, hesaplarını silebilme, sohbet geçmişine erişebilme gibi ayrıcalıklı işlemler gerçekleştirebildiği tespit ve kavram kanıtı (PoC) ile doğrulanmıştır.

Zafiyet, sistemin tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.